

# 11 · Seguridad

Documentacion del sistema

Version analizada: **0.3.0**

Commit analizado: **ff246ab**

Fecha de generacion: **2026-08-27**

Generado a partir de 11-security.md — los Markdown son la fuente unica.  
No editar este PDF: editar el Markdown y regenerar.

## Contenido de este documento

---

1. Modelo de amenaza declarado por el proyecto
2. Lo que está bien y hay que proteger
3. Autenticación y autorización
4. El sandbox: qué protege de verdad
5. La superficie de mayor riesgo: ``system.run_powershell``
6. Almacenamiento de datos sensibles
7. Dependencias
8. Riesgos de inyección: revisión punto por punto
9. Controles ausentes
10. Comprobación de secretos en el repositorio
11. Protección de datos personales
12. Recomendaciones priorizadas
13. Lo que este análisis NO comprobó

Superficie de ataque, controles **presentes** y controles **ausentes**, medidos sobre el código del commit analizado. No se ejecutó ninguna prueba destructiva ni ningún ataque contra sistemas externos: todo lo que sigue es análisis estático más ejecución de la suite de pruebas del propio repositorio. Los hallazgos se describen **sin publicar cadenas explotables**.

## 1. Modelo de amenaza declarado por el proyecto

El repositorio no esconde su situación. `.github/workflows/security.yml` abre con un comentario que es, de hecho, el modelo de amenaza:

«este repo ejecuta acciones de teclado/mouse/captura de pantalla en el equipo del operador. Un commit malicioso fusionado a main se traduce directamente en RCE local cuando el operador hace pull.»

Esa frase ordena bien las prioridades: **la cadena de suministro es el vector principal**, porque el producto, por diseño, ya tiene permiso para hacer casi cualquier cosa en la máquina. Y el repositorio invierte en consecuencia (\$2).

### Activos a proteger

| Activo                            | Dónde vive                                                         | Por qué importa                                                |
|-----------------------------------|--------------------------------------------------------------------|----------------------------------------------------------------|
| La sesión de Windows del operador | El equipo                                                          | El sistema puede teclear, hacer clic y lanzar procesos en ella |
| Capturas del escritorio           | <code>output/screenshots/*.png</code>                              | Pueden contener cualquier cosa visible en pantalla             |
| Contenido del portapapeles        | <code>output/reports/clipboard_*.json</code> , SQLite              | Puede contener credenciales recién copiadas                    |
| Histórico completo                | <code>db/runs.db</code> , <code>state/</code> , <code>logs/</code> | Contiene todo lo anterior, sin cifrar                          |
| Tokens del panel                  | <code>secrets/secrets.json</code> o entorno                        | Sin cifrar                                                     |
| El propio catálogo de flows       | <code>flows/*/manifest.json</code>                                 | Un manifest es código ejecutable en la práctica                |

## 2. Lo que está bien y hay que proteger

Un informe que solo enumerase problemas daría una imagen falsa. Estos controles están implementados, verificados y algunos son mejores que la media del sector.

### 2.1 Hardening de la cadena de suministro — 12 capas

`SECURITY.md` documenta la política completa. Verificado en los workflows:

| # | Capa                                        | Evidencia en el repositorio                                                                                                                  |
|---|---------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | SHA pin en toda acción de terceros          | <code>actions/checkout@9c091bb...</code> ,<br><code>astral-sh/setup-uv@fac544c...</code> ,<br><code>github/codeql-action/*@8aad20d...</code> |
| 2 | <code>pin-check</code> con parser YAML real | <code>.github/workflows/workflow-security.yml</code> ,<br>job <code>pin-check</code>                                                         |
| 3 | Allowlist de excepciones vacía              | Sin excepciones silenciosas                                                                                                                  |
| 4 | <code>persist-credentials: false</code>     | En <b>todos</b> los <code>checkout</code>                                                                                                    |
| 5 | Permisos mínimos por job                    | <code>permissions: contents: read</code> ;<br><code>release.yml</code> arranca con <code>permissions: {}</code>                              |

|    |                                                                              |                                                                                                                                                                        |
|----|------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 6  | <code>concurrency: cancel-in-progress</code>                                 | En <code>ci</code> , <code>security</code> , <code>workflow-security</code> , <code>markdown-docs</code> , <code>dependency-hygiene</code>                             |
| 7  | Sin <code>pull_request_target</code>                                         | Verificado: no se usa como disparador en ningún workflow. La única aparición es un comentario de <code>workflow-security.yml</code> que lo lista como patrón prohibido |
| 8  | CodeQL <code>security-extended</code>                                        | <code>security.yml</code> , con <code>security-and-quality</code> añadido                                                                                              |
| 9  | <code>actionlint</code> (con verificación de checksum) + <code>zizmor</code> | <code>workflow-security.yml</code>                                                                                                                                     |
| 10 | <code>detect-secrets</code> sobre filesystem y 50 commits de historial       | <code>security.yml</code> , con <code>fetch-depth: 0</code>                                                                                                            |
| 11 | Detección de Trojan Source, ofuscación y URLs de exfiltración                | <code>security.yml</code>                                                                                                                                              |
| 12 | <code>pip-audit</code>                                                       | <code>security.yml</code>                                                                                                                                              |

La capa 10 es la más infrecuente: escanear el árbol completo en cada uno de los últimos 50 commits detecta un secreto **aunque se haya borrado después**.

La capa 9 verifica el **checksum del propio `actionlint`** antes de ejecutarlo, cerrando el caso de una herramienta de seguridad comprometida.

## 2.2 Sanitización de entrada en el panel

| Control                                | Implementación                                                                                                            | Cierra                           |
|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| Slug de <code>folder</code>            | <code>_FOLDER_RE = ^[A-Za-z0-9_\-]{1,64}\$</code> aplicado en las 7 rutas que reciben un folder                           | Path traversal, NUL, no-ASCII    |
| Path traversal en <code>/file</code>   | Cuatro controles en cascada; ver §2.3                                                                                     | CWE-22                           |
| XSS reflejado desde <code>/file</code> | Allowlist negativa de 8 extensiones + <code>X-Content-Type-Options: nosniff</code>                                        | CWE-79                           |
| Escapado del HTML del panel            | <code>html.escape</code> en las rutas de renderizado                                                                      | CWE-79                           |
| Comparación de tokens                  | <code>hmac.compare_digest</code>                                                                                          | CWE-208 (fuga por temporización) |
| Anti-CSRF sin token                    | <code>Host</code> loopback + <code>Origin/Referer</code> coherentes                                                       | CSRF, DNS rebinding              |
| Command injection                      | <code>shell=True</code> prohibido en <code>ui.launch_process</code> ; <code>shlex.split</code> + <code>shell=False</code> | CWE-78                           |
| Inyección en PowerShell                | Tokens prohibidos + allowlist de verbos                                                                                   | CWE-78                           |
| Inyección SQL                          | Todas las consultas son parametrizadas con <code>?</code>                                                                 | CWE-89                           |
| Sanitización del tag en release        | Regex <code>^v\d+\.\d+\.\d+([-.]?[\w]+)?\$,</code> con <code>throw</code> si no coincide                                  | Inyección en el pipeline         |

Los comentarios del código citan explícitamente los CWE que cierran. Es una práctica poco habitual y muy útil para auditar.

## 2.3 Los cuatro controles de `/file`, en orden

1. Rechaza `\x00` y cualquier carácter de control (`ord(c) < 32`)
2. Rechaza rutas absolutas
3. `normpath(join(base, rel))` debe empezar por `base + os.sep`
4. Extensión no puede estar en `{.html .htm .xhtml .xml .svg .js .mjs .css}` → 415

El `os.sep` del punto 3 es el detalle fino: sin él, un directorio hermano llamado `repo-evil` pasaría el `startswith` de `repo`. El comentario del código lo señala.

Cubierto por `tests/test_security_hardening.py`.

## 2.4 Higiene de secretos en el resultado

`notify.send` con `backend: "webhook"` resuelve el token y lo usa en la cabecera `Authorization`, pero el `record` que devuelve no lo incluye. Es correcto y deliberado: ese resultado va al contexto y de ahí a `runs.context_json`.

`engine.secrets.list_secret_names()` devuelve nombres, nunca valores.

## 2.5 Salidas de red opt-in

Con la configuración por defecto, el sistema no genera tráfico de red. Verificado leyendo los 27 `context.example.json`: los nueve flows de navegador apuntan a HTML locales del repositorio, y los dos con notificación usan `backend: "file"`.

# 3. Autenticación y autorización

## 3.1 No hay usuarios

No existe autenticación de usuario, ni sesión, ni roles, ni permisos. El README del repositorio lo declara: «Multiusuario / RBAC — [alto] No — un operador local».

El modelo de confianza es: *quien tiene la sesión de Windows tiene el sistema*. Es coherente con un producto de escritorio, pero conviene enunciarlo porque cambia la lectura de todo lo demás.

## 3.2 Protección de las mutaciones: dos modos

```
# app/server.py::_authorize_mutation
panel_token = get_secret('AUTOMA_PANEL_TOKEN')
if panel_token:
    return (True, '') if self._check_token('AUTOMA_PANEL_TOKEN') else (False, 'token inválido ...')

host_only = (self.headers.get('Host') or '').split(':', 1)[0].lower()
if host_only not in {'127.0.0.1', 'localhost', ':::1', ':::1'}:
    return False, 'Host no loopback: cliente remoto debe usar AUTOMA_PANEL_TOKEN'
origin = self.headers.get('Origin')
if origin and origin != expected_origin: return False, ...
referer = self.headers.get('Referer')
if referer and not referer.startswith(expected_origin + '/') and referer != expected_origin:
    return False, ...
return True, ''
```

**Modo 1 · con token.** Toda mutación exige `X-Automa-Token` idéntico, comparado en tiempo constante. Robusto.

**Modo 2 · sin token.** Tres comprobaciones que cierran el ataque real: una web maliciosa que el operador visita y que intenta `fetch('http://127.0.0.1:8787/api/run/...')`. El navegador **siempre** envía `Origin` en un `fetch` cross-site, así que se bloquea.

**Lo que el modo 2 no cubre, y hay que decirlo:** las comprobaciones de `Origin` y `Referer` son condicionales (`if origin and ...`). Un cliente que **no envíe** esas cabeceras —`curl`, un script Python, cualquier proceso local— pasa el control con solo poner `Host: 127.0.0.1`. Es una decisión calibrada contra el navegador, no contra un proceso local hostil. El comentario del código es honesto sobre cuál es el caso que cubre.

## 3.3 Las lecturas no están protegidas

`do_GET` no llama a `_authorize_mutation` en ningún caso. Verificado leyendo el método completo. Consecuencia: incluso con `AUTOMA_PANEL_TOKEN` definido, siguen abiertos:

| Ruta                        | Qué expone                                                                                              |
|-----------------------------|---------------------------------------------------------------------------------------------------------|
| GET /api/runs               | <b>context_json</b> completo de cada corrida: portapapeles, texto OCR, contenido web, inventarios       |
| GET /api/flows              | Catálogo con todos los pasos y parámetros                                                               |
| GET /api/metrics,/metrics   | Volumen, duraciones, tasas de fallo                                                                     |
| GET /file?path=...          | Cualquier archivo bajo la raíz salvo 8 extensiones. Los <b>.png</b> de las capturas <b>SÍ</b> se sirven |
| GET /run/<flow_id>/<run_id> | Detalle completo en HTML                                                                                |

Este es el hallazgo de mayor impacto del documento. Con el panel escuchando en loopback y un solo usuario, el riesgo real es bajo. Deja de serlo si alguien cambia el bind, monta un reverse proxy, o si hay más de una cuenta en el equipo.

### 3.4 El webhook

POST /api/hook/<folder> exige AUTOMA\_WEBHOOK\_TOKEN siempre, independientemente del modo. Sin la variable definida responde 401: está **deshabilitado por defecto**. Es la decisión correcta para la única superficie pensada para llamadas no locales.

**REQUIERE VALIDACIÓN:** el webhook es **síncrono**. Una petición contra un flow largo mantiene la conexión abierta y no hay límite de peticiones concurrentes. **INFERENCIA:** un atacante con el token podría agotar recursos disparando el mismo flow muchas veces —el **run\_locks** no se aplica en esta ruta.

## 4. El sandbox: qué protege de verdad

### 4.1 Es declarativo, no de sistema operativo

docs/SEGURIDAD.md lo declara y el README lo marca como «[bajo] Sandbox declarativo, no proceso». El motor comprueba nombres de acción y prefijos de ruta **antes** de llamar a la función. Una vez dentro, la acción corre con **todos los permisos del usuario**: no hay contenedor, ni jaula, ni token restringido, ni AppContainer.

### 4.2 La mayoría del catálogo no lo usa

Conteo verificado leyendo los 27 manifests:

| Control             | Flows que lo declaran | Flows sin él      |
|---------------------|-----------------------|-------------------|
| allowed_actions     | 13 (08–20)            | 14 (01–07, 21–27) |
| allowed_paths       | 7 (09, 12, 15–19)     | 20                |
| max_runtime_seconds | 13 (08–20)            | 14                |
| required_secrets    | 0                     | 27                |

Entre los 14 sin política están:

- **07\_browser\_form\_filler** — lanza un navegador visible y escribe archivos.
- **Los siete flows web (21–27)** — salen a internet si se cambia la URL.
- **01, 03, 04, 05, 06** — leen el sistema de archivos y el estado del equipo.

**INFERENCIA:** el bloque 08–20 se añadió en la v0.2.0 con la política ya en mente, y la familia web de la v0.3.0 no la incorporó. No hay ninguna regla en la CI que exija declarar **allowed\_actions**, así que el hueco puede crecer con cada caso nuevo.

### 4.3 La detección de rutas es por nombre de clave

```
if any(token in key.lower() for token in ('path', 'destination', 'source', 'output', 'file')):
```

`assert_paths_allowed` considera candidata a ruta **cualquier cadena cuya clave contenga** uno de esos cinco fragmentos. Consecuencias verificadas:

| Parámetro                                                                                                                                  | ¿Se comprueba?                  |
|--------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|
| <code>output_path</code> , <code>save_data_path</code> , <code>seeds_path</code> , <code>state_path</code> , <code>track_state_path</code> | [OK]                            |
| <code>target</code> de <code>browser.extract_content / capture_page</code>                                                                 | [NO] (puede ser una ruta local) |
| <code>command</code> de <code>ui.launch_process</code>                                                                                     | [NO] (contiene una ruta)        |
| <code>path</code> de <code>filesystem.*</code>                                                                                             | [OK]                            |

En el catálogo actual no abre un agujero, porque ninguno de los siete flows con `allowed_paths` usa esas acciones. Pero un autor de flows que confíe en `allowed_paths` para acotar un flow de navegador tendría una protección que no protege.

4.4 `max_runtime_seconds` no es un timeout

Se comprueba **entre pasos**. Una acción que se cuelga dentro no se interrumpe. Un `browser.crawl_site` contra un servidor lento, o un `http.check_urls` de 100 URLs con timeout de 10 s, pueden superar largamente el límite sin que nada los corte. Es un control de *arranque de paso*.

4.5 `required_secrets` mira solo el entorno

`SandboxPolicy.check_required_secrets` usa `os.environ.get`, no `engine.secrets.get_secret`. Un secreto que viva solo en `secrets/secrets.json` **no satisface** el requisito y el flow no arranca. Incoherencia entre dos mecanismos presentados como equivalentes.

5. La superficie de mayor riesgo: `system.run_powershell`

Dos controles bien contruidos y una puerta abierta por diseño.

Los controles:

```
forbidden_chars = (";", "|", "&", "`", ">", "<", "$(", "$_")
for token in forbidden_chars:
    if token in trimmed:
        raise ValueError(...)
verbs = tuple(allowlist) if allowlist else _PS_DEFAULT_ALLOWLIST
head = trimmed.split()[0]
if head not in verbs:
    raise ValueError(...)
```

Se ejecuta con `shell=False` y argumentos como lista, `-NoProfile -NonInteractive`. Los 13 verbos por defecto son todos `Get-*` de solo lectura.

**La puerta abierta:** el parámetro `allowlist` es **sobrescribible desde el manifest**. Un flow que declare `"allowlist": ["Remove-Item"]` obtiene exactamente eso, y los tokens prohibidos no impiden un comando destructivo de una sola palabra con argumentos.

**Lectura correcta:** no es una vulnerabilidad explotable desde fuera —requiere escribir un manifest, es decir, tener ya acceso de escritura al repositorio o al directorio de flows—. Pero significa que **la seguridad de esta acción depende de la revisión de código de los manifests, no de un control del motor**. Es exactamente el modelo de amenaza que `security.yml` describe, y por eso el hardening del CI es la defensa correcta.

**NO IDENTIFICADO:** ninguna regla de `scripts/validate_project.py` comprueba los `params` de un paso. Un manifest con una `allowlist` ampliada pasa la validación sin comentarios.

6. Almacenamiento de datos sensibles

| Dato | Almacén | Cifrado | Control de acceso |
|------|---------|---------|-------------------|
|------|---------|---------|-------------------|

|                        |                                                |                  |                                      |
|------------------------|------------------------------------------------|------------------|--------------------------------------|
| Tokens del panel       | <code>secrets/secrets.json</code>              | [NO] Texto plano | Permisos del sistema de archivos     |
| Histórico completo     | <code>db/runs.db</code>                        | [NO]             | Permisos del sistema de archivos     |
| Portapapeles capturado | SQLite +<br><code>output/reports/*.json</code> | [NO]             | Igual                                |
| Capturas de escritorio | <code>output/screenshots/*.png</code>          | [NO]             | Igual, más <b>GET /file</b> sin auth |
| Texto OCR de ventanas  | SQLite + reportes                              | [NO]             | Igual                                |
| Salida de PowerShell   | SQLite + reportes                              | [NO]             | Igual                                |

**No hay cifrado en reposo en ningún punto.** El docstring de `engine/secrets.py` lo declara sin adornos: «permisos del FS son el control de acceso». Para un producto local de un solo usuario es defendible; en un equipo compartido o con respaldo automático a la nube, no.

**No hay retención ni purga.** Verificado buscando `VACUUM`, `DELETE FROM runs`, `retention` y `backup` en todo el código: no existe ninguna rutina. Un flow programado cada 15 minutos genera 96 corridas diarias, cada una con su fila en SQLite, su `.jsonl` y su `.json` de estado, indefinidamente.

## 7. Dependencias

### Política declarada

`pyproject.toml` fija un piso explícito por paquete, con el motivo escrito:

«Cotas de seguridad: piso explícito = primera versión sin CVE conocida al corte de la auditoría 2026-06-01 (ver SECURITY.md §"Auditoría 2026-06").»

Es una política razonada, no un rango arbitrario. Todas las dependencias llevan además cota superior de *major* (<13, <8, <3...), lo que evita saltos de versión mayor inesperados.

### Lo que no está pinneado

**No hay lockfile versionado.** El comentario de `requirements.txt` lo reconoce: «Para reproducibilidad estricta usar `uv export` (lockfile en CI) — este archivo solo fija un piso seguro». Verificado: no existe `uv.lock` ni `requirements.lock` en `git ls-files`.

**INFERENCIA:** dos instalaciones en fechas distintas pueden resolver versiones distintas dentro del mismo rango. Un escáner de vulnerabilidades sobre las declaraciones no puede pronunciarse con precisión sobre versiones no fijadas.

### `requirements.txt` incompleto

Declara seis paquetes y le faltan `pyperclip`, `PyGetWindow` y `pywebview`, que sí están en `pyproject.toml`. `make install` usa ese archivo. No es un riesgo de seguridad, pero deja el entorno incompleto.

### Análisis de vulnerabilidades

`pip-audit` corre en `security.yml` (soft en PR, hard en `main`). **No se ejecutó en este análisis:** **REQUIERE VALIDACIÓN.** La CI del repositorio es la fuente para ese dato.

### Dependencias con superficie especial

| Paquete                                | Superficie                                                          |
|----------------------------------------|---------------------------------------------------------------------|
| <code>pyautogui</code>                 | Control de teclado y ratón: si se compromete, controla la sesión    |
| <code>playwright</code> (no declarado) | Descarga y ejecuta un Chromium completo                             |
| <code>pywebview</code>                 | Motor de navegador embebido ( <code>edgechromium</code> en Windows) |

|             |                                       |
|-------------|---------------------------------------|
| pytesseract | Invoca un binario externo del sistema |
|-------------|---------------------------------------|

## 8. Riesgos de inyección: revisión punto por punto

| Vector                     | Estado                   | Evidencia                                                                                                                                                                                                                           |
|----------------------------|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SQL injection              | [OK] Cerrado             | Todas las consultas usan ?. Sin concatenación de strings en SQL                                                                                                                                                                     |
| Command injection (shell)  | [OK] Cerrado             | shell=True prohibido con ValueError; shlex.split + shell=False                                                                                                                                                                      |
| PowerShell injection       | [!] Mitigado             | Tokens prohibidos + allowlist; pero la allowlist es sobrescribible desde el manifest                                                                                                                                                |
| Path traversal             | [OK] Cerrado en el panel | _safe_folder + los 4 controles de /file                                                                                                                                                                                             |
| Path traversal en acciones | [!] Parcial              | allowed_paths es opcional y solo lo declaran 7 flows                                                                                                                                                                                |
| XSS reflejado              | [OK] Mitigado            | Allowlist de extensiones en /file + nosniff + html.escape                                                                                                                                                                           |
| XSS almacenado             | [!] REQUIERE VALIDACIÓN  | El panel renderiza contenido de las corridas; el escapado se aplica en las rutas revisadas, pero el HTML se construye por concatenación de f-strings en ~660 líneas. Una ruta sin html.escape sería difícil de detectar por lectura |
| CSRF                       | [OK] Mitigado            | Modo 2 de _authorize_mutation                                                                                                                                                                                                       |
| DNS rebinding              | [OK] Mitigado            | Comprobación de Host loopback                                                                                                                                                                                                       |
| SSRF                       | [!] Abierto por diseño   | http.fetch_url, check_urls y browser.* aceptan cualquier URL, incluidas IPs internas. Es la funcionalidad del producto                                                                                                              |
| Deserialización insegura   | [OK] Sin riesgo          | Solo json.loads. Sin pickle, yaml.load ni eval                                                                                                                                                                                      |
| Carga de archivos          | [OK] Sin superficie      | No hay endpoint de subida. POST /api/form/submit escribe JSON con nombre generado por el servidor                                                                                                                                   |

Verificación de la penúltima fila:

```
grep -rn "pickle\|eval(\|exec(\|yaml.load\|os.system" --include="*.py" \
  engine/ actions/ app/ plugins/ decision/
```

Sin resultados en el código de producción.

## 9. Controles ausentes

Lista honesta de lo que **no** existe, verificado por búsqueda:

| Control ausente                   | Impacto                                | Prioridad sugerida |
|-----------------------------------|----------------------------------------|--------------------|
| Autenticación en los GET          | Todo el histórico es legible sin token | Alta               |
| Cifrado en reposo de secrets.json | Tokens en texto plano                  | Media              |

|                                                                |                                                                                       |       |
|----------------------------------------------------------------|---------------------------------------------------------------------------------------|-------|
| Cifrado del histórico                                          | Capturas, OCR y portapapeles sin cifrar                                               | Media |
| Retención y purga de datos                                     | Crecimiento sin límite                                                                | Media |
| <code>allowed_actions</code> obligatorio en la CI              | 14 flows sin política                                                                 | Alta  |
| Validación de <code>params</code> contra la firma de la acción | Un manifest puede ampliar la allowlist de PowerShell sin aviso                        | Alta  |
| Timeout real por acción                                        | <code>max_runtime_seconds</code> no interrumpe                                        | Media |
| Lock en las rutas del panel                                    | El mismo flow puede correr dos veces en paralelo                                      | Media |
| Lockfile de dependencias                                       | Superficie no auditable con precisión                                                 | Media |
| Cabeceras de seguridad (CSP, X-Frame-Options, Referrer-Policy) | Solo se emite <code>nosniff</code> , y solo en <code>/file</code>                     | Baja  |
| Límite de tasa en el webhook                                   | Agotamiento de recursos con token válido                                              | Baja  |
| Registro de auditoría de accesos al panel                      | <code>log_message</code> está <b>silenciado</b> a propósito                           | Baja  |
| <code>ruff format --check</code> en la CI                      | El hook existe en pre-commit pero la CI no lo aplica                                  | Baja  |
| Firma de código del <code>.exe</code>                          | <code>codesign_identity=None</code> en <code>automa.spec</code> ; SmartScreen avisará | Baja  |
| Rotación de tokens                                             | Sin mecanismo                                                                         | Baja  |

## Sobre el registro silenciado

```
def log_message(self, format: str, *args: Any) -> None: # silencia logs ruidosos
    return
```

`AppHandler.log_message` está sobrescrito para no imprimir nada. Es razonable para no llenar la consola de la ventana nativa, pero significa que **no queda ningún registro de qué peticiones recibió el panel**. Las corridas sí quedan en SQLite; los accesos de lectura, no.

## 10. Comprobación de secretos en el repositorio

Realizada durante este análisis sobre el árbol versionado:

```
grep -rni "(sk-|ghp_|gho_|AKIA|BEGIN [A-Z ]*PRIVATE KEY|password\s*=\s*[\"'])[^\"]{6,}|api[_-]?key\s*[:=])" \
$(git ls-files '*.py' '*.json' '*.toml' '*.md' '*.yaml' '*.ps1' '*.iss')
```

**Sin coincidencias de credenciales reales.** Las seis coincidencias del patrón son todas benignas y se listan aquí para que la comprobación sea reproducible:

| Archivo                                                      | Qué es                                                                                                                                               |
|--------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>actions/vision.py</code> (x2)                          | Nombres de parámetro: <code>vision_api_key</code> , <code>api_key=</code>                                                                            |
| <code>plugins/analyzers/vision_model_analyzer.py</code> (x3) | Nombres de parámetro: <code>api_key</code>                                                                                                           |
| <code>docs/OPERACION.md</code> línea 130                     | Ejemplo de documentación: <code>set_secret("MY_API_KEY", "sk-...")</code> . El valor es literalmente <code>sk-...</code> , un marcador, no una clave |

`secrets/` contiene únicamente `.gitkeep`. `.gitignore` excluye `secrets/*.json`, `db/*.db`, `logs/*.jsonl`, `state/*.json` y las salidas de `output/`.

La CI hace lo mismo con `detect-secrets==1.5.0` y además escanea los últimos 50 commits.

## 11. Protección de datos personales

**NO IDENTIFICADO:** no existe ninguna funcionalidad de privacidad. Sin anonimización, sin redacción de campos, sin consentimiento, sin política de retención, sin exportación ni borrado a petición.

Los datos que el sistema captura pueden ser personales o sensibles según lo que haya en pantalla o en el portapapeles del operador. Como todo permanece en el equipo y no sale a la red, la responsabilidad recae íntegramente en quien lo opera.

**Recomendaciones para el operador, INFERENCIA** a partir de la arquitectura:

1. No ejecute `15_clipboard_capture` con credenciales en el portapapeles.
2. Revise `output/screenshots/` antes de compartir el equipo o hacer respaldo.
3. Si el equipo tiene sincronización a la nube, excluya `output/`, `db/`, `logs/` y `state/`.
4. Defina `AUTOMA_PANEL_TOKEN` si hay más de una cuenta en el equipo — aunque recuerde que **no protege las lecturas**.
5. Purgue periódicamente a mano: no hay retención automática.

## 12. Recomendaciones priorizadas

Ninguna se aplicó: este documento es informativo, igual que 15 · Riesgos y deuda técnica.

| # | Recomendación                                                                                                                                                  | Esfuerzo                                   | Impacto |
|---|----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|---------|
| 1 | Exigir token también en <code>GET /api/runs, /api/flows, /api/metrics</code> y <code>/file</code> cuando <code>AUTOMA_PANEL_TOKEN</code> esté definido         | Bajo (una llamada en <code>do_GET</code> ) | Alto    |
| 2 | Añadir a <code>validate_project.py</code> una regla que exija <code>allowed_actions</code> en todo flow nuevo                                                  | Bajo                                       | Alto    |
| 3 | Validar los <code>params</code> de cada paso contra la firma de la acción ( <code>inspect.signature</code> )                                                   | Medio                                      | Alto    |
| 4 | Bloquear el override de <code>allowlist</code> en <code>system.run_powershell</code> , o exigir una lista blanca de allowlists                                 | Bajo                                       | Alto    |
| 5 | Comprobar también <code>value</code> (no solo la clave) en <code>assert_paths_allowed</code> para detectar rutas en <code>target</code> y <code>command</code> | Medio                                      | Medio   |
| 6 | Generar y versionar un lockfile ( <code>uv export</code> )                                                                                                     | Bajo                                       | Medio   |
| 7 | Timeout real por acción con <code>concurrent.futures</code> o señal                                                                                            | Medio                                      | Medio   |
| 8 | Rutina de retención configurable                                                                                                                               | Medio                                      | Medio   |
| 9 | Aplicar <code>run_locks</code> también en las rutas del panel y del webhook                                                                                    | Bajo                                       | Medio   |

|    |                                                                      |       |       |
|----|----------------------------------------------------------------------|-------|-------|
| 10 | Cifrar <code>secrets.json</code> con DPAPI en Windows                | Medio | Medio |
| 11 | Auditar el escapado HTML de las ~660 líneas de renderizado del panel | Medio | Medio |
| 12 | Añadir <code>ruff format --check</code> a la CI                      | Bajo  | Bajo  |

### 13. Lo que este análisis NO comprobó

| Aspecto                                                                              | Motivo                                                                            |
|--------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Vulnerabilidades conocidas de las dependencias                                       | No se ejecutó <code>pip-audit</code> ni consulta a bases de CVE. La CI sí lo hace |
| Pruebas de penetración del panel                                                     | Fuera del alcance: sin pruebas destructivas                                       |
| XSS almacenado real                                                                  | Requeriría inyectar contenido en una corrida y observar el render                 |
| Comportamiento del binario empaquetado                                               | No se compiló                                                                     |
| Efectividad de <code>zizmor</code> , <code>actionlint</code> y CodeQL en este commit | Requiere ver las ejecuciones en GitHub Actions                                    |
| Permisos efectivos de los archivos en Windows                                        | No se auditaron las ACL                                                           |
| Resistencia a carga o denegación de servicio                                         | Sin pruebas de estrés                                                             |

**Documentos relacionados:** [03 · Arquitectura](#) · [07 · Base de datos](#) · [08 · Flujo de datos](#) · [10 · Configuración](#) · [15 · Riesgos y deuda técnica](#)